Software Requirements Specification

Version 1.1 | 29 October 2026 | Status: Review (approved policy, proposed technical details)

1. Purpose and Scope

CommerceFlow is a portfolio-grade e-commerce MVP. Guests browse active products; authenticated customers manage their own carts, checkout, and view orders; administrators manage products, inventory, and order status. Real payments and payment-card handling are out of scope.

This document specifies target behavior; it does not claim features are implemented.

2. Architecture and Constraints

Frontend: React and TypeScript. Backend: Java 21, Spring Boot modular monolith, Spring Security, Spring Session JDBC. Data: PostgreSQL 17 and Flyway. REST API prefix: /api/v1.

USD only, decimal-string amounts in API, NUMERIC(12,2) in PostgreSQL. Product-level inventory. Guest cart is deferred; authenticated customers only. Mock payment only.

10 business tables: users, roles, user_roles, categories, products, carts, cart_items, orders, order_items, order_addresses. Spring Session and checkout_idempotency are infrastructure tables outside this count.

3. Actors and Authorization

Guest: browse/search/view products and register. Customer: login, manage own cart, checkout, cancel eligible own orders, view own orders. Admin: catalog, stock, and order management. Admin identities are provisioned securely, not by public registration.

Protected endpoints return 401 when unauthenticated; unauthorized role returns 403; other customers' orders return 404 to avoid existence disclosure. State-changing session-authenticated requests require CSRF protection.

4. Functional Requirements

- FR-01 Customer registration with unique normalized email and validation.
- FR-02 Login establishes a server-side session; cookie is HttpOnly, Secure in production, with reviewed SameSite and CSRF behavior.
- FR-03 Store passwords with an approved adaptive hash; never log secrets.
- FR-04 Enforce customer/admin role-based access on server.
- FR-05 Logout invalidates session and prevents reuse.
- FR-06 List active products with pagination.
- FR-07 Search and filter active products.
- FR-08 Retrieve product details.

- FR-09 Customer creates/updates/removes own cart items; no guest cart in MVP.
- FR-10 Validate quantities, current active product, prices, and available inventory at checkout.
- FR-11 Checkout creates at most one confirmed order for a successful logical request; persist immutable item and shipping-address snapshots, decrement stock atomically, clear cart, and store idempotency outcome. Failed mock payment creates no order and changes no inventory.
- FR-12 Customer views own order history and order details.
- FR-13 Enforce ownership on all order/cart access; no cross-user disclosure.
- FR-14 Admin creates, edits and deactivates products (not destructive deletion of referenced products).
- FR-15 Admin changes stock with nonnegative constraint and concurrency-safe behavior.
- FR-16 Admin manages supported order transitions; cancellation permitted only from CONFIRMED, with stock restoration exactly once in the same transaction.
- FR-17 Validate request payloads and report field-level errors.
- FR-18 Use consistent structured API errors, including 409 conflicts for key reuse/mismatch and in-progress duplicate checkout.

5. Checkout Policy (Approved v1.0)

- CP-01 Retain completed idempotency results for at least 24 hours after completion. After expiry, duplicate suppression is not guaranteed.
- CP-02 Scope idempotency key to authenticated customer. Identical explicit checkout request with the same key replays the original result (including original 201 status on success), without a new order or stock change.
- CP-03 Same key with different canonical explicit request fields (including shipping address) returns HTTP 409. The original cart snapshot is frozen on first processing; do not compare retries against a cart cleared by the original checkout.
- CP-04 Concurrent same-key request cannot run twice; a duplicate while first request is processing receives retriable HTTP 409.
- CP-05 Only CONFIRMED -> CANCELLED is permitted for cancellation; restore reserved stock once, atomically. Repeated cancellation cannot restore it again.
- CP-06 Checkout transaction must prevent overselling, using conditional inventory updates; the order, inventory mutation, cart clearing, and completed idempotency result must be coordinated to avoid partial success.

6. Nonfunctional Requirements

- NFR-01 Security: server-side session, CSRF, role/ownership checks, password hashing, no card data, safe logs.
- NFR-02 Proposed performance acceptance: product listing p95 <= 500 ms at 20 concurrent virtual users with 1,000 seeded products in a documented environment. This is an unmeasured target.
- NFR-03 Atomic checkout, inventory consistency, idempotent replay, cancellation consistency, and recovery from interruptions.
- NFR-04 Maintainable modular boundaries, documented decisions, versioned Flyway migrations, testability.
- NFR-05 Health endpoint, safe logging, controlled errors, and CI verification.

- NFR-06 Accessible, understandable UI and actionable validation feedback.

7. Acceptance and Traceability

All FR/NFR requirements must map to automated test cases and release evidence. Required high-risk scenarios: stock=1 simultaneous checkouts; same-key retry after cart clearing; key mismatch; in-progress duplicate; cancel twice; crash at transaction boundary; CSRF failure; cross-user order access.

Detailed technical handling for stale IN_PROGRESS leases, deterministic mock-payment failure replay, and CSRF deployment bootstrap remain design-review items; these must be resolved before implementation of the affected features.

8. Status and Change Control

Status: REVIEW v1.1. Checkout Policy v1.0 is approved. Recovery mechanisms and payment failure semantics are proposed, not approved. No code, migrations, or GitHub changes are part of this documentation package.